

OneNest AI

Business Requirements Document

Document ID: ONE-BRD-v1.0

Version: 1.0

Status: Final

Date: 20 August 2026

Author: Kanha Gupta

Application: OneNest AI — Personal Life OS

1. Executive Summary & Business Context

1.1 Vision Statement

OneNest AI is a cloud-deployable, AI-augmented personal productivity platform that consolidates an individual's entire personal workspace — notes, tasks, finances, documents, and health records — into a single, secure, privacy-first application. The platform combines structured data management with a locally-embedded semantic search engine and a Retrieval-Augmented Generation (RAG) AI assistant, enabling users to not just store information but to query, understand, and derive insights from their own content.

1.2 Business Problem

Modern individuals maintain fragmented digital lives across dozens of disconnected applications: note-taking apps, to-do managers, expense trackers, cloud drives, medical record folders, and AI chatbots. This fragmentation creates three compounding problems:

- Context loss: AI assistants cannot reference personal data stored elsewhere.
- Data silos: notes, finances, and health data are trapped in incompatible systems.
- Privacy risk: personal data is scattered across multiple third-party services.

OneNest AI solves these problems by providing a single, self-contained workspace where the AI assistant has contextual awareness of all stored personal data, semantic search operates across every note and document, and the entire application can be deployed on a cost-free cloud tier.

1.3 Strategic Objectives

- SO-01: Provide a unified personal data repository covering notes, tasks, finances, documents, and health.
- SO-02: Embed an AI assistant with workspace awareness capable of answering questions grounded in the user's own content (RAG).
- SO-03: Implement zero-cost local semantic search using ONNX inference — no embedding API costs.
- SO-04: Enforce strong per-user data isolation with JWT authentication and role-based access control.
- SO-05: Support production deployment on Render free tier with Supabase PostgreSQL and Supabase Storage.
- SO-06: Provide an administrative interface for platform operators to manage users and support tickets.

1.4 Scope

In Scope

- User authentication and account lifecycle (register, login, password change, account deletion)
- Personal workspace modules: Notes, Tasks, Expenses, Documents, Health Hub
- AI Assistant with multi-turn conversation history and workspace context injection
- RAG pipeline: local ONNX embedding → pgvector similarity search → Gemini generation
- Semantic search across notes and documents with background auto-indexing
- Document text extraction and AI-powered summarization
- Health Hub: medicines, appointments, medical records, medical reports (with file upload)
- Settings: account, storage, measurements, security, appearance, notifications
- Admin panel: user management, contact message management
- Contact & support messaging system
- Dashboard with aggregated analytics and Chart.js visualizations
- Production deployment on Render (Docker backend, Static Site frontend) with Supabase

Out of Scope

- Mobile native applications (iOS / Android)
- Real-time collaborative editing or shared workspaces
- Email or push notification dispatch (settings stored but dispatch not implemented)
- Payment processing or premium tier billing
- OAuth / social login providers

2. Stakeholders & User Personas

2.1 Stakeholder Map

Stakeholder	Role	Primary Concern
End User (Regular)	User role	Secure, private personal data management; AI-assisted retrieval
Platform Administrator	Admin role	Platform health; user management; support ticket resolution
Platform Developer / Owner	Kanha Gupta	Technical correctness; deployment reliability; cost efficiency

2.2 User Personas

P-01: The Organized Professional

A working professional (25–40 years) managing projects, tracking finances, maintaining health records, and wanting AI assistance without sending personal data to third-party services.

- Needs private local semantic search over personal notes
- Wants AI aware of tasks and expenses without manual copy-paste
- Tracks medicines and appointments in one place

P-02: The Student

A university student managing coursework documents, tasks with deadlines, and a tight budget.

- Uses document AI summarization for study materials
- Relies on task priority and due-date validation
- Benefits from RAG to ask questions over uploaded study documents

P-03: The Platform Admin

A technical administrator with elevated privileges to manage all users and respond to support tickets.

- Visibility into all contact messages across all users
- Ability to toggle user roles (promote/demote admins)
- Monitors platform via health check endpoint

3. Functional Requirements

3.1 Authentication & Account Management

ID	Requirement	Priority
FR-AUTH-001	Users shall register with full name, email, and password (min 6 chars). 409 on duplicate email.	Must Have
FR-AUTH-002	Users shall authenticate via email/password and receive a JWT (includes userId, role, expiry).	Must Have
FR-AUTH-003	JWT expiry shall be validated client-side; expired tokens redirect to /login without API call.	Must Have
FR-AUTH-004	Users shall change password; new must differ from current; current verified server-side.	Must Have
FR-AUTH-005	Users shall permanently delete account (password-confirmed); all data purged.	Must Have
FR-AUTH-006	Role-based access restricts /api/Admin/* to Admin role; non-admins receive 403.	Must Have

3.2 Notes Module

ID	Requirement	Priority
FR-NOTE-001	CRUD operations on personal notes; all scoped to current user.	Must Have
FR-NOTE-002	Pin/unpin notes; pinned notes sorted to top of list.	Should Have
FR-NOTE-003	Client-side search by title and content; reactive; no API round-trip.	Should Have
FR-NOTE-004	Notes paginated at 5 per page.	Should Have
FR-NOTE-005	Create/update note triggers background semantic indexing (fire-and-forget).	Must Have

3.3 Tasks Module

ID	Requirement	Priority
FR-TASK-001	Create tasks with title, description, due date, and priority (Low/Medium/High; default Medium).	Must Have
FR-TASK-002	Due dates validated to not be in the past (custom notPastDate validator).	Must Have
FR-TASK-003	Toggle completion; completed tasks visually distinguished (CSS class).	Must Have
FR-TASK-004	Client-side search by title and description; paginated at 5 per page.	Should Have

3.4 Expense Tracker Module

ID	Requirement	Priority
FR-EXP-001	Record income and expense transactions with amount (>0), date, category (10 types), type, notes.	Must Have
FR-EXP-002	Filter by category, transaction type; sort by date or amount.	Should Have
FR-EXP-003	Expense summary: total income, total expense, balance, monthly breakdown, category breakdown.	Must Have
FR-EXP-004	Currency displayed in Indian Rupees (₹); en-IN locale.	Must Have

3.5 Document Vault Module

ID	Requirement	Priority
FR-DOC-001	Upload documents (PDF, Office, images, text) up to 25 MB per file. Extension allowlist enforced server-side.	Must Have
FR-DOC-002	Total storage per user shall not exceed 150 MB (documents + health reports combined).	Must Have
FR-DOC-003	Duplicate original filenames rejected (409 Conflict).	Must Have

FR-DOC-004	Inline preview for PDF (iframe), image (img), text; other types trigger download.	Should Have
FR-DOC-005	Text auto-extracted from documents at upload time (best-effort; never blocks upload).	Must Have
FR-DOC-006	AI summarization triggered on demand; Gemini generates 3–5 sentence summary from ExtractedText.	Should Have
FR-DOC-007	Download individual document or all as ZIP (Documents/ + Health-Reports/ folders).	Should Have
FR-DOC-008	Deleting a document removes DB record and Supabase Storage file.	Must Have

3.6 Health Hub Module

ID	Requirement	Priority
FR-HLT-001	Manage medicines: name, dosage, frequency, timing (morning/afternoon/night), food timing, active flag, dates.	Must Have
FR-HLT-002	Manage appointments: doctor, hospital, specialty, date, time, status (Scheduled/Completed/Cancelled).	Must Have
FR-HLT-003	Single health record per user (upsert): blood group, height, weight, allergies, conditions, emergency contact.	Must Have
FR-HLT-004	BMI auto-calculated from height/weight; read-only; category labels (Underweight/Normal/Overweight/Obese).	Must Have
FR-HLT-005	Height/weight stored in SI (cm/kg); displayed in user-preferred units (cm/ft, kg/lb).	Must Have
FR-HLT-006	Upload health reports (25 MB limit): category (LabReport/Prescription/Scan/DischargeSummary/Other).	Must Have
FR-HLT-007	Health reports count toward the shared 150 MB storage quota.	Must Have

3.7 AI Assistant Module

ID	Requirement	Priority
FR-AI-001	Create, manage, rename, archive, and delete multi-turn AI conversations.	Must Have
FR-AI-002	AI receives workspace context (notes/tasks/expenses/health/documents summaries) before generating.	Must Have
FR-AI-003	Workspace tool selection uses Gemini planner + keyword matching (union, deduplicated).	Must Have
FR-AI-004	Messages display workspace metadata: tools used, response mode.	Should Have
FR-AI-005	Gemini rate limit (429) surfaced to user as specific error toast.	Must Have
FR-AI-006	Message content supports markdown rendering (headings, bold, code, lists).	Should Have

3.8 RAG Module

ID	Requirement	Priority
FR-RAG-001	Users query personal content with natural language; receive grounded answer + source citations.	Must Have
FR-RAG-002	Embed query (ONNX 384-dim) → pgvector cosine search → filter by threshold ≥ 0.70 .	Must Have
FR-RAG-003	Sources cited with type (Note/Document), title, chunk index. SourceId NOT exposed.	Must Have
FR-RAG-004	Context capped at 12,000 characters (Gemini context budget).	Must Have
FR-RAG-005	Retrieved content XML-escaped inside <SOURCES> delimiter (prompt injection protection).	Must Have
FR-RAG-006	No-results path returns friendly explanation (HasSources=false).	Must Have

3.9 Semantic Search Module

ID	Requirement	Priority
FR-SEM-001	Semantic similarity search over notes and documents; returns ranked results with score.	Must Have
FR-SEM-002	Deduplicate results: only highest-scoring chunk per source returned.	Must Have
FR-SEM-003	Backfill endpoint re-indexes all user content in background (202 Accepted immediately).	Should Have
FR-SEM-004	Status endpoint reports provider readiness, dimension, row count.	Should Have
FR-SEM-005	Auto-index on note create/update and document upload (background, fire-and-forget).	Must Have

4. Non-Functional Requirements

ID	Category	Requirement	Measure
NFR-001	Security	All API endpoints except /api/health require JWT Bearer.	401 without valid token
NFR-002	Security	All queries scoped to authenticated user's userId.	No cross-user data leakage
NFR-003	Security	Passwords hashed via ASP.NET Identity PasswordHasher.	Bcrypt; plaintext never stored
NFR-004	Security	RAG content XML-escaped before prompt construction.	RagContextBuilder escapes &, <, >
NFR-005	Security	File storage: user-scoped dirs + GUID filenames.	Path.GetFileName() prevents traversal
NFR-006	Performance	ONNX embedding inference completes within 500 ms per chunk.	Local INT8 model; ~22 MB
NFR-007	Performance	pgvector search over <10K rows completes within 50 ms.	Sequential scan at personal scale
NFR-008	Performance	Background semantic indexing does not delay HTTP responses.	Fire-and-forget Task.Run in new DI scope
NFR-009	Reliability	ONNX model integrity verified at Docker build via SHA256.	Build aborts on mismatch
NFR-010	Reliability	Tokenizer vocabulary verified at Docker build time.	RUN test -f Vocabularies/base_uncased.txt
NFR-011	Availability	Cold-start recovery within Render 15-minute spin-down window.	/api/health returns; no runtime model download
NFR-012	Scalability	File storage uses Supabase Storage (survives container restarts).	SupabaseFileStorageService in production
NFR-013	Maintainability	Clean Architecture: Domain/Application/Infrastructure/API.	No cross-layer dependency violations
NFR-014	Cost	Embeddings use local ONNX model; no embedding API key required.	Embeddings__Provider=Local

5. Data Model

5.1 Entity Overview

All domain entities carry a UserId (Guid) FK ensuring per-user data isolation. PostgreSQL with pgvector extension. EF Core manages all entities except EmbeddingRecords (raw ADO.NET).

Entity	Key Fields	Notes
User	Id, FullName, Email (unique), PasswordHash, Role, LastLoginAt	Email normalized lowercase
Note	Id, UserId, Title, Content, IsPinned, IsArchived	Semantic index on create/update
TaskItem	Id, UserId, Title, Description, DueDate, Priority(1/2/3), IsCompleted	Priority: Low=1, Medium=2, High=3
Expense	Id, UserId, Title, Amount(18,2), Category(1-10), TransactionType(1/2), Date	INR currency
Document	Id, UserId, Title, OriginalFileName, StoredFileName, FileSize, ExtractedText, AISummary	25 MB/file; 150 MB total
Medicine	Id, UserId, Name, Dosage, Frequency, Morning, Afternoon, Night, FoodTiming, IsActive	FoodTiming: Before/After/Anytime
Appointment	Id, UserId, DoctorName, Hospital, Specialty, Date, Time, Status	Status: Scheduled/Completed/Cancelled
MedicalRecord	Id, UserId, BloodGroup, HeightCm(6,2), WeightKg(6,2), Allergies, EmergencyContact*	One per user; upsert
MedicalReport	Id, UserId, Title, Category, DoctorName, ReportDate, StoredFileName, FileSize	Toward 150 MB quota
AIConversation	Id, UserId, Title, IsArchived, IsDeleted, LastMessageAt	Cascade delete to AIMessages
AIMessage	Id, ConversationId, Role(0=User/1=Asst), Content, IsError	Metadata as HTML comment in Content
UserSettings	Id, UserId(unique), Theme, DefaultHeightUnit, DefaultWeightUnit	Default: theme=system
ContactMessage	Id, UserId, Subject, Message, Category(0-3), Status(0-2), AdminReply	Status: 0=New,1=Read,2=Resolved
EmbeddingRecord	Id, UserId, SourceType(0=Note/1=Doc), SourceId, ChunkIndex, Embedding(vector(384))	pgvector; unique(User,Type,Source,Chunk)

5.2 Enumeration Definitions

Enum	Values
ExpenseCategory	Food=1, Travel=2, Shopping=3, Bills=4, Entertainment=5, Health=6, Education=7, Salary=8, Investment=9, Other=10
TransactionType	Income=1, Expense=2
DocumentCategory	Resume=1, Certificate=2, Identity=3, Medical=4, Invoice=5, Finance=6, Education=7, Personal=8, Other=9
TaskPriority	Low=1, Medium=2, High=3
AppointmentStatus	Scheduled=1, Completed=2, Cancelled=3
MedicineFoodTiming	BeforeFood=1, AfterFood=2, Anytime=3
MedicalReportCategory	LabReport=1, Prescription=2, Scan=3, DischargeSummary=4, Other=5
EmbeddingSourceType	Note=0, Document=1

ContactCategory	General=0, Support=1, Bug=2, Feedback=3
ContactStatus	New=0, Read=1, Resolved=2

6. AI & RAG Architecture

6.1 AI Interaction Modes Comparison

Mode	Endpoint	Embeddings	Gemini	Sources	Description
Normal AI Chat	POST /api/ai/conversations/{id}/messages	No	Yes	No	Multi-turn with workspace context injection (notes/tasks/expenses summaries).
Semantic Search	POST /api/semantic-search	Query only	No	Yes (ID+Score)	Pure vector similarity; no AI generation; returns ranked source items.
RAG Query	POST /api/ai/rag	Query+Retrieve	Yes	Yes (Type+Title)	Full pipeline: embed→search→retrieve→generate. Grounded Q&A over personal content.

6.2 RAG Pipeline — 9-Step Flow

- Step 1 — Validate Query: Reject empty queries with 400 Bad Request.
- Step 2 — Embed Query: LocalEmbeddingProvider (ONNX all-MiniLM-L6-v2, INT8, 384-dim) produces float[384] vector.
- Step 3 — Vector Search: pgvector cosine similarity against EmbeddingRecords; fetch topK×10 raw candidates scoped to userId.
- Step 4 — Filter & Deduplicate: Apply threshold ≥ 0.70 ; deduplicate by (SourceType, SourceId); take topK (default 5, max 20).
- Step 5 — Fetch Source Text: Load Note.Content or Document.ExtractedText for each winner; strictly user-scoped.
- Step 6 — Build Context: RagContextBuilder assembles XML-escaped content inside <SOURCES>...</SOURCES>; cap at 12,000 chars.
- Step 7 — Assemble Prompt: System prompt + SOURCES block + up to 10 prior conversation messages + current query.
- Step 8 — Gemini Generation: GeminiProvider calls gemini-2.5-flash; retries 3× on 429/5xx with 300–600 ms backoff.
- Step 9 — Return: RagResponse { Answer, Sources[], HasSources, Model, Timestamp }. SourceId omitted for security.

6.3 Workspace Context Tools (Normal Chat)

Tool	Trigger Keywords	Data Provided
NotesWorkspaceTool	note, notes, remember, summarize my notes	Total count, pinned count, 5 recent notes (title + 120-char preview)
TasksWorkspaceTool	task, tasks, todo, pending, overdue, due	Total, pending, overdue counts; top 5 pending tasks by due date
ExpensesWorkspaceTool	expense, spending, budget, money, finance, income, salary	Financial summary (income, expense, balance, category breakdown)
HealthWorkspaceTool	medicine, appointment, health, doctor, prescription	Health summary (active medicines, upcoming appointments)
DocumentsWorkspaceTool	document, file, pdf, resume, certificate	Document summary (total, storage used, recent uploads)

6.4 Local Embedding Model

Property	Value
Model	Xenova/all-MiniLM-L6-v2 (INT8 dynamic-quantized)

Output Dimensions	384-dimensional float32 vectors
File Size	~22 MB (vs ~86 MB FP32)
SHA256	afdb6f1a0e45b715d0bb9b11772f032c399babd23bfc31fed1c170afc848bdb1
Inference Runtime	Microsoft.ML.OnnxRuntime
Tokenizer	BERTTokenizers v1.2.0 — BertUncasedBaseTokenizer
Max Input Tokens	512 WordPiece tokens; chunk size ~1200 chars (~300 tokens)
Cost	Zero — no API key required; runs inside Docker container

6.5 Text Chunking Parameters

Parameter	Default	Purpose
ChunkSizeChars	1200 chars	≈300 BERT tokens; within 512 token limit
ChunkOverlapChars	240 chars	60-token overlap preserves cross-chunk context
Splitting Strategy	Sentence-aware	Splits at '. ! ?' + newlines; preserves sentence boundaries
Hard Split Fallback	Word boundary	For over-long segments without a natural split point

7. Key User Journeys

UJ-01: New User Registration & First Login

- 1. User navigates to /register — two-panel page (brand hero left, form right).
- 2. Fills Full Name (min 2 chars), Email, Password (min 6 chars); submits.
- 3. API validates uniqueness; 409 on duplicate email; error displayed.
- 4. On success: JWT stored in localStorage; user navigated to /dashboard.
- 5. Dashboard displays time-of-day greeting; all sections show empty states.

UJ-02: Upload Document and Ask RAG Question

- 1. User navigates to /documents; selects file (PDF, max 25 MB).
- 2. Fills title and category; submits upload.
- 3. Backend saves to Supabase Storage; extracts text; semantic index created in background.
- 4. User navigates to /ai-assistant; opens RAG panel ('■ Ask Your Content').
- 5. Types natural language question; submits.
- 6. RAG: embed query → pgvector search → fetch document text → Gemini generates grounded answer.
- 7. Answer displayed with source chips showing ■ Document title and chunk index.

UJ-03: Track Health Record and View BMI

- 1. User navigates to /health → Records tab.
- 2. Enters blood group, height, weight (in preferred units from Settings).
- 3. BMI auto-calculated in read-only field; category label shown.
- 4. User clicks info button → BMI popup with range table.
- 5. Saves; single record upserted via PUT /api/MedicalRecords.

UJ-04: Admin Manages Support Ticket

- 1. Admin navigates to /admin (adminGuard verifies role='Admin' in JWT).
- 2. Messages tab shows all contact messages; badge displays New count.
- 3. Admin expands message; clicks 'Reply / Update Status'.
- 4. Sets status to Resolved; writes reply; saves.
- 5. PATCH /api/Admin/messages/{id}/status persists; user sees reply on /contact.

8. API Contract Summary

All endpoints prefixed /api. JWT Bearer required except /api/health and auth endpoints. ASP.NET Core 10; Swagger at /swagger in Development mode.

Authentication

Endpoint	Auth	Description
POST /api/Auth/register	None	Register new user; 409 on duplicate email
POST /api/Auth/login	None	Authenticate; returns JWT
POST /api/Auth/change-password	JWT	Change password
POST /api/Auth/delete-account	JWT	Delete account (password-confirmed)

Notes

Endpoint	Auth	Description
GET/POST /api/Notes	JWT	List or create notes
PUT/DELETE /api/Notes/{id}	JWT	Update or delete note
PATCH /api/Notes/{id}/pin	JWT	Toggle pin

Documents

Endpoint	Auth	Description
GET /api/Documents	JWT	List (search/category filter)
POST /api/Documents	JWT	Upload (multipart; max 25 MB)
PUT/DELETE /api/Documents/{id}	JWT	Update metadata / delete
DELETE /api/Documents/all	JWT	Delete all
GET /api/Documents/{id}/download	JWT	Download as attachment
GET /api/Documents/download-all	JWT	Download all as ZIP
GET /api/Documents/{id}/preview	JWT	Preview inline
GET /api/Documents/summary	JWT	Storage stats
POST /api/Documents/{id}/summarize	JWT	Trigger AI summarization

AI Assistant

Endpoint	Auth	Description
GET/POST /api/ai/conversations	JWT	List or create conversations
GET /api/ai/conversations/{id}	JWT	Get conversation with messages
PUT /api/ai/conversations/{id}/rename	JWT	Rename
DELETE /api/ai/conversations/{id}	JWT	Delete
POST /api/ai/conversations/{id}/archive	JWT	Archive / Unarchive
POST /api/ai/conversations/{id}/messages	JWT	Send message; returns AI response
POST /api/ai/rag	JWT	RAG query (embed→search→generate)

Semantic Search

Endpoint	Auth	Description
----------	------	-------------

POST /api/semantic-search	JWT	Semantic similarity search
POST /api/semantic-search/backfill	JWT	Re-index all content (202)
GET /api/semantic-search/status	JWT	Provider diagnostics

Health Hub

Endpoint	Auth	Description
GET/POST/PUT/DELETE /api/Medicines	JWT	Manage medicines
GET/POST/PUT/DELETE /api/Appointments	JWT	Manage appointments
GET/PUT /api/MedicalRecords	JWT	Get / upsert health record
GET/POST/PUT/DELETE /api/MedicalReports	JWT	Manage health reports (file)
GET /api/health-hub/summary	JWT	Health analytics summary

Admin

Endpoint	Auth	Description
GET /api/Admin/messages	JWT+Admin	All contact messages
PATCH /api/Admin/messages/{id}/status	JWT+Admin	Update status/reply
GET /api/Admin/users	JWT+Admin	All users
PATCH /api/Admin/users/{id}/role	JWT+Admin	Change user role

System

Endpoint	Auth	Description
GET /api/health	None	Health check (status, version, timestamp)
GET/PUT /api/Settings	JWT	Get or update user settings
POST /api/Contact	JWT	Submit support message
GET /api/Contact/my	JWT	Own message history
GET /api/Contact/summary	JWT	Message status counts
GET/PUT /api/Expenses/summary	JWT	Expense summary analytics

9. Validation Rules

Field	Module	Rule
Email	Auth	Valid format; unique in DB (case-insensitive, normalized to lowercase)
Password (register)	Auth	Minimum 6 characters
Full Name	Auth	Required; minimum 2 characters
Task Due Date	Tasks	Required; must not be in the past (notPastDate validator)
Expense Amount	Expenses	Required; must be > 0
Document File	Documents	Max 25 MB; allowed extensions; no duplicate OriginalFileName
Medicine Name + Start Date	Health	Both required
Appointment Doctor + Date + Time	Health	All required
Display Name	Settings	Required; max 120 characters
Contact Subject	Contact	Max 200 characters
Contact Message	Contact	Max 2,000 characters
AI Chat Message	AI	Max 8,000 characters
RAG Query	RAG	Non-empty; max 2,000 characters

10. Deployment Architecture

10.1 Architecture Overview



10.2 Key Environment Variables

Variable	Required	Description
ConnectionStrings__DefaultConnection	Yes	Supabase PostgreSQL connection string
Jwt__Key	Yes	JWT signing key (min 64 chars)
AI__ApiKey	Yes	Google Gemini API key
AI__Model	Yes	gemini-2.5-flash
Embeddings__Provider	Yes	Local
Embeddings__Dimension	Yes	384
Supabase__Url	Yes	https://<project-ref>.supabase.co
Supabase__ServiceRoleKey	Yes	Supabase service-role key
Supabase__StorageBucket	Yes	onenest-documents
Cors__AllowedOrigins__0	Yes	https://<angular-app>.onrender.com

10.3 Docker Multi-Stage Build

Stage	Base Image	Purpose
build	mcr.microsoft.com/dotnet/sdk:10.0	Restore + publish app; verify tokenizer vocabulary (fail-fast)
model-download	debian:bookworm-slim	Download all-MiniLM-L6-v2 ONNX; SHA256-verify
runtime	mcr.microsoft.com/dotnet/aspnet:10.0	Final image with app + model; non-root 'app' user

11. Security Architecture

Concern	Mechanism	Detail
Authentication	JWT Bearer Tokens	Signed token with userId, role, exp; validated server-side every request
Authorization	RBAC	[Authorize] all APIs; [Authorize(Roles='Admin')] on AdminController
Multi-Tenancy	UserId scoping	ICurrentUserService extracts userId; all queries WHERE UserId = @userId
Password Storage	ASP.NET Identity PasswordHasher	Bcrypt-based; plaintext never stored or logged
Client-Side Expiry	JWT exp decoded in AuthService	Guard redirects before making stale-token API calls
File Security	GUID filenames + user dirs	StoredFileName = GUID+ext; original name in DB only
Prompt Injection	XML escape + SOURCES delimiter	Retrieved content escaped; inside <SOURCES> block; Gemini told it's plain data
TLS	Render edge + ForwardedHeaders	HttpsRedirection removed (would loop); X-Forwarded-Proto trusted
Storage Quota	Server-side check before every upload	150 MB total; 400 on overflow

12. Technology Stack

Layer	Technology	Version / Notes
Frontend	Angular	22.1 — standalone components, signals, computed, toSignal
Frontend State	Angular Signals	signal(), computed(), effect() — no NgRx
Frontend Charts	Chart.js	Pie, bar, doughnut charts on dashboard
Backend	ASP.NET Core	.NET 10 — controllers + minimal middleware
Architecture	Clean Architecture	Domain / Application / Infrastructure / API
ORM	Entity Framework Core	Npgsql.EntityFrameworkCore.PostgreSQL
Database	PostgreSQL + pgvector	Supabase hosted; vector(384) for embeddings
Auth	JWT Bearer	Microsoft.AspNetCore.Authentication.JwtBearer
File Storage	Supabase Storage REST API	Private bucket; service-role key; S3-compatible
AI Generation	Google Gemini API	gemini-2.5-flash; 3× retry with backoff
Local Embeddings	ONNX Runtime	all-MiniLM-L6-v2 INT8; 384-dim; ~22 MB
Tokenizer	BERTTokenizers v1.2.0	BertUncasedBaseTokenizer; vocab from NuGet content file
Containerization	Docker	Multi-stage: sdk → debian (model) → aspnet runtime
Cloud Platform	Render	Free tier: Docker Web Service + Static Site

13. Requirements Traceability Matrix

Req ID	Description	API Endpoint(s)	Frontend Component	Domain Entity
FR-AUTH-001	User registration	POST /api/Auth/register	register.component.ts	User
FR-AUTH-002	User login	POST /api/Auth/login	login.component.ts	User
FR-AUTH-004	Change password	POST /api/Auth/change-password	settings.component.ts	User
FR-AUTH-005	Delete account	POST /api/Auth/delete-account	settings.component.ts	User
FR-NOTE-001-005	Notes CRUD + pin + index	/api/Notes/*	notes.component.ts	Note, EmbeddingRecord
FR-TASK-001-004	Tasks CRUD + complete	/api/Tasks/*	tasks.component.ts	TaskItem
FR-EXP-001-004	Expenses CRUD + summary	/api/Expenses/*	expenses.component.ts	Expense
FR-DOC-001-008	Documents upload/preview/AI	/api/Documents/*	documents.component.ts	Document
FR-HLT-001-007	Health Hub all tabs	/api/Medicines, Appointments, MedicalRecords, MedicalReports	health.component.ts	Medicine, Appointment, MedicalRecord, MedicalReport
FR-AI-001-007	AI conversations	/api/ai/conversations/*	ai-assistant.component.ts	AIConversation, AIMessage
FR-RAG-001-007	RAG pipeline	POST /api/ai/rag	ai-assistant.component.ts	EmbeddingRecord, Note, Document
FR-SEM-001-005	Semantic search + backfill	/api/semantic-search/*	—	EmbeddingRecord
FR-SET-001-005	Settings management	GET/PUT /api/Settings	settings.component.ts	UserSettings
FR-ADM-001-005	Admin panel	/api/Admin/*	admin.component.ts	User, ContactMessage
FR-CON-001-003	Contact & support	/api/Contact/*	contact.component.ts	ContactMessage

14. Glossary

Term	Definition
RAG	Retrieval-Augmented Generation — retrieves relevant documents from vector DB, uses as grounding context for LLM generation.
pgvector	PostgreSQL extension enabling vector(N) column type and cosine similarity search (<=>) operator.
ONNX	Open Neural Network Exchange — open ML model format. Used for all-MiniLM-L6-v2 embedding model.
Embedding	Dense numerical vector encoding semantic meaning of text; semantically similar texts have nearby vectors.
Cosine Similarity	Angular similarity measure (-1 to 1; higher = more similar). OneNest threshold: ≥ 0.70 .
Backfill	Generating embeddings for existing content; needed when indexing is newly introduced.
Chunking	Splitting long text into overlapping segments fitting the embedding model's token limit.
Workspace Context	User's personal data (notes/tasks/expenses) injected into AI system prompt.
JWT	JSON Web Token — signed self-contained token with userId, role, expiry claims.
Supabase	Open-source Firebase alternative: managed PostgreSQL (with pgvector) + Storage API.
ForwardedHeaders	ASP.NET Core middleware reading X-Forwarded-* headers from Render's TLS proxy.
Clean Architecture	Domain/Application/Infrastructure/API layering; no upward dependencies.
IFileStorageService	C# interface abstracting file storage: SupabaseFileStorageService in production.

15. Appendices

15.1 Database Migration Timeline

Migration	Date	Purpose
InitialCreate	2026-08-03	Notes and Tasks tables
AddAuthAndUserOwnership	2026-08-03	Users table; UserId FK on all entities
AddExpenses	2026-08-03	Expenses table
AddDocuments	2026-08-03	Documents table with file storage
AddHealthHub	2026-08-03	Medicines, Appointments, MedicalRecords, MedicalReports
AddAIConversationHistory	2026-08-04	AIConversations and AIMessages
AddUserSettings	2026-08-04	UserSettings table
AddUserLastLoginAt	2026-08-05	LastLoginAt column on User
AddContactAndUserRole	2026-08-17	ContactMessages table; Role column on User
AddDocumentTextExtraction	2026-08-17	ExtractedText, IsTextExtracted, AISummary on Document
AddSemanticEmbeddings	2026-08-17	EmbeddingRecords (vector(384)); pgvector extension

15.2 Angular Route Map

Route	Component	Auth Guard	Admin Guard
/login	LoginComponent	No	No
/register	RegisterComponent	No	No
/dashboard	DashboardComponent	authGuard	No
/notes	NotesComponent	authGuard	No
/tasks	TasksComponent	authGuard	No
/expenses	ExpensesComponent	authGuard	No
/documents	DocumentsComponent	authGuard	No
/health	HealthComponent	authGuard	No
/ai-assistant	AiAssistantComponent	authGuard	No
/contact	ContactComponent	authGuard	No
/admin	AdminComponent	authGuard	adminGuard
/settings	SettingsComponent	authGuard	No

15.3 File Type Allowlist

.pdf, .doc, .docx, .xls, .xlsx, .ppt, .pptx, .txt, .csv, .rtf, .jpg, .jpeg, .png, .gif, .bmp, .webp

15.4 Known Limitations & Future Backlog

- Notification dispatch: reminder settings stored in DB but background scheduler not yet wired.
- Auto-delete trash: autoDeleteTrashDays (default 30) stored but cleanup job not implemented.
- ANN vector index: HNSW recommended above ~50K rows (m=16, ef_construction=64).
- Embedding provider switch (Local→Gemini): requires schema change vector(384→768) + full re-backfill.
- RAG over Medical Reports: file text extraction not implemented for reports; reports not semantically indexed.

- Render free tier cold start: first request after 15-min inactivity may take 20–30 s to spin up.